Compliance-платформа для финтех-стартапов — PRD v1.0

Собрано из: brief.md, competitive_analysis_final.md, audit/audit_report.md, personas.md, interview_compliance_officer.md, features_list.md, prioritization.md, mvp_scope.md

1. Executive Summary

Продукт: B2B SaaS / RegTech-платформа, объединяющая KYC, AML, санкционный/PEP-скрининг и GDPR/PDPA-контекст в одной подписке для растущих финтех-стартапов.

Проблема: Регуляторная сложность (KYC/AML/санкции/GDPR) сегодня либо решается разрозненными точечными вендорами, либо enterprise-платформами, недоступными по цене и скорости внедрения для растущего (не крупного) финтех-стартапа. Внутри компании это создаёт постоянный конфликт: product хочет скорость онбординга, compliance — безопасность и защитимость решений.

Ключевой инсайт из исследования: Ни один из пяти проанализированных конкурентов (Sumsub, Alloy, ComplyAdvantage, Persona, Unit21) не показывает риск-матрицу как явный UI-паттерн, не формализует 4-eyes как отдельную роль и статус, и не визуализирует расхождение данных между источниками вместо усреднённого скора. Это не просто продуктовые пробелы — с 2 августа 2026 EU AI Act требует human oversight и traceability для AML-риск-профилирования, а дело SCHUFA (CJEU C-634/21) юридически запрещает формальный человеческий sign-off без реальной власти отменить AI-решение. Наши дифференциаторы — не предпочтение дизайнера, а регуляторное требование, реализованное раньше конкурентов.

Решение: MVP — экран разбора кейса с матрицей риск-тиров (Low/Medium/High), явным показом расхождения источников, explainability-блоком прямо в карточке и формализованным 4-eyes вместо решения вопросов в Slack.

Primary-персона и её JTBD: Compliance Officer — «нанимает» продукт, чтобы быстро и защитимо решить KYC/AML-кейс: одобрить, отклонить или эскалировать, не становясь узким местом для бизнеса и сохраняя след, который переживёт аудит.

2. Цели и метрики

> **North Star Metric:** Доля решений по кейсам, закрытых в срок своего риск-тира с полным защитимым аудит-следом. Одна метрика, отражающая одновременно обе стороны конфликта брифа — скорость (product) и защитимость (compliance).

Objective 1: Compliance-офицеры решают кейсы быстрее, не теряя защитимость

- KR1: 100% Low-риск кейсов закрываются автоматически за секунды, без участия человека
- KR2: Среднее time-to-decision по Medium/High-риску — ниже индустриального бенчмарка 20–40 минут на алерт
- KR3: False positive rate отслеживается с первого дня как baseline для v1.1

Objective 2: Продукт воспринимается как защитимый инструмент, а не формальность

- KR1: 100% решений, включая Low-авто-одобрения, имеют полный аудит-след
- KR2: 0 случаев «тихого» дефолтного решения без явной пометки источника (авто / human / timeout)
- KR3: Override rate по типу флага отслеживается с первого релиза

Objective 3: Compliance перестаёт быть невидимым тормозом роста

- KR1: Onboarding conversion становится измеримой и обсуждаемой метрикой между CPO и compliance-командой
- KR2: 0% клиентов, столкнувшихся с bill shock, в первый год
- KR3: Retention среди Compliance Officer-пользователей к концу v1.1

3. Целевая аудитория

Персона	Приоритет	JTBD
Compliance Officer	Primary	Быстро и защитимо решить KYC/AML-кейс — одобрить, отклонить или эскалировать, не становясь узким местом и сохраняя аудируемый след
Senior Compliance Officer	Secondary (право вето на High-risk)	Вынести защитимое решение по эскалации (4-eyes), доказав регулятору, что человеческий надзор реален, а не формальность
CPO / Product Manager	Secondary	Измерить и снизить «compliance-налог» на конверсию онбординга, договориться о конкретных порогах вместо стихийного трения

Compliance Officer использует продукт ежедневно (десятки кейсов), Senior Compliance Officer — по требованию (несколько раз в неделю), CPO — еженедельно.

4. Конкурентный ландшафт

Проанализированы 5 конкурентов: Sumsub, Alloy, ComplyAdvantage (Mesh), Persona, Unit21. Ни один не закрывает одновременно доступный self-serve вход для растущего стартапа, полный стек KYC+AML+sanctions+GDPR/PDPA в одной подписке и UX кейс-менеджмента вокруг риск-тиров и объяснимости. Persona ближе всех по UX, но узка по AML-глубине; Sumsub близок по широте, но дорог и медленно внедряется; Alloy/Unit21 архитектурно ближе всего к нашей модели, но оба — закрытые sales-led продукты без публичной цены.

Ключевые дифференциаторы

Дифференциатор	Есть у конкурентов?	Регуляторное основание
Риск-матрица Low/Medium/High как явный UI-паттерн	Ни у одного из 5	EU AI Act ст.14 (human oversight), GDPR ст.22
4-eyes: формализованная роль + статус кейса	Ни у одного (Unit21 — частичный guardrail)	Дело SCHUFA (C-634/21) — override должен быть реальным

Explainability-блок прямо в карточке кейса	Ни у одного в UI	EU AI Act ст.11/13 (traceability)
Явный показ расхождения источников	Ни у одного из 5	Ответ на «data inaccuracy» — 7 упоминаний на G2 у ComplyAdvantage

5. MVP Scope

Одно предложение: MVP — инструмент, где Compliance Officer разбирает KYC/AML-кейс на одном экране с прогрессивным раскрытием, видит риск-тир и расхождение источников, а несогласие с AI эскалирует формально через 4-eyes вместо Slack.

Must have фичи

1. **KYC / ID-верификация (Sumsub)** — базовый источник данных о личности заявителя
2. **AML / санкции / PEP screening (ComplyAdvantage)** — скрининг по спискам
3. **Матрица риск-тиров (Low/Medium/High) с эскалацией** — явный UI-паттерн
4. **Auto-одобрение Low с фиксацией в аудит-логе**
5. **Soft-block Medium с SLA**
6. **Жёсткое вето High**
7. **4-eyes: роль Senior Compliance Officer + статус «Ожидает подтверждения»** (базовая версия)
8. **Состояния кейса** — полный жизненный цикл
9. **Экран разбора кейса с прогрессивным раскрытием**
10. **Explainability-блок AI-вердикта в карточке**
11. **Явный показ расхождения источников**
12. **Аудит-лог** — кто/когда/что + версия модели/входные данные
13. **Accessibility WCAG 2.1 AA + риск не только цветом**
14. **Дизайн-система с нуля**

Основной сценарий (Compliance Officer)

Вход → Очередь кейсов → Открытие кейса → сводка (identity + риск-тир + explainability) → расхождение источников видно сразу → прогрессивное раскрытие деталей по клику → решение по тиру (Low авто / Medium в рамках SLA / High с explicit-подтверждением или эскалацией в 4-eyes) → запись в аудит-лог → закрытие кейса.

Что осознанно НЕ входит (Should have → v1.1)

1. **Внутренний поведенческий скоринг** — модель не на чем обучать до накопления реальных кейсов
2. **SLA-таймер эскалации + маршрутизация на роль + три статуса решения** — требует статистики от работающего базового 4-eyes
3. **Дашборд CPO** — вторичная персона, метрики бессмысленны без накопленной истории

6. User Stories

Для каждой Must have фичи. Priority везде Must (v1.0).

> **1. KYC / ID-верификация**
>
> Как Compliance Officer, я хочу видеть результаты проверки личности заявителя прямо в карточке кейса, чтобы не переключаться в отдельный инструмент.
>
> AC: карточка показывает имя/дату рождения/страну/статус верификации; данные обновляются автоматически; при недоступности Sumsub — явное состояние ошибки.

> **2. AML / санкции / PEP screening**
>
> Как Compliance Officer, я хочу видеть результаты скрининга отдельно по каждому типу списка, чтобы оценить риск без похода во внешний отчёт.
>
> AC: статус по каждому списку отдельно; совпадение помечено подписью и иконкой, не только цветом; клик раскрывает детали.

> **3. Матрица риск-тиров с эскалацией**
>
> Как Compliance Officer, я хочу видеть явный риск-тир кейса, чтобы понимать механизм его решения.
>
> AC: явный тир виден в списке и карточке; обозначен формой/иконкой; правило единое для всех клиентов на MVP.

> **4. Auto-одобрение Low**
>
> Как Compliance Officer, я хочу, чтобы Low-риск кейсы закрывались автоматически с записью в лог.
>
> AC: Low-кейс получает Approved без действия человека; запись «авто-одобрено по правилу X» с timestamp; officer может просмотреть кейс в любой момент.

> **5. Soft-block Medium с SLA**
>
> Как Compliance Officer, я хочу, чтобы Medium-кейсы ждали моего ревью в рамках SLA.
>
> AC: статус «На проверке»; виден оставшийся SLA-срок; по истечении — визуальная пометка просрочки.

> **6. Жёсткое вето High**
>
> Как Compliance Officer, я хочу, чтобы High-кейс не мог пройти без моего явного действия.
>
> AC: не переходит в Approved без явного действия; интерфейс не даёт закрыть без просмотра explainability; требуется явный клик подтверждения.

7. 4-eyes: роль + статус «Ожидает подтверждения»

Как Compliance Officer, я хочу формально эскалировать кейс, с которым не согласен.

AC: перевод в статус одним действием; кейс виден в очереди Senior Compliance Officer; полный контекст доступен; решение и обоснование логируются.

8. Состояния кейса

Как Compliance Officer, я хочу видеть этап кейса, чтобы понимать, что делать дальше.

AC: явный статус жизненного цикла; история смены статусов в карточке; нет кейсов без статуса.

9. Прогрессивное раскрытие

Как Compliance Officer, я хочу видеть сводку сразу и детали по необходимости.

AC: сразу видны identity/риск-тир/explainability/расхождение источников; детали по клику без перехода на другой экран; простой кейс решается без разворота деталей.

10. Explainability-блок

Как Compliance Officer, я хочу видеть, на основе чего вынесен вердикт.

AC: указана версия модели; показаны конкретные входные данные/правила; блок виден без дополнительных переходов.

11. Явный показ расхождения источников

Как Compliance Officer, я хочу видеть, если источники расходятся, чтобы не усреднять вслепую.

AC: расхождение — отдельный явно читаемый элемент; не скрыто в агрегированном скоре; видно, что нашёл каждый источник.

12. Аудит-лог

Как Compliance Officer и Senior Compliance Officer, я хочу полный неизменяемый след действий по кейсу.

AC: каждое действие записано с timestamp/user ID/версией модели/входными данными; доступен read-only из карточки; не редактируется пользователем.

13. Accessibility WCAG 2.1 AA

Как Compliance Officer с особенностями цветовосприятия, я хочу понимать риск не только по цвету.

AC: риск-тир и статус находки — с текстовой подписью и/или иконкой формы; базовая проверка контраста и клавиатурной навигации; нет пар элементов, различающихся только оттенком.

> **14. Дизайн-система**
>
> Как команда разработки, мы хотим единый набор компонентов.
>
> AC: базовые компоненты переиспользуются на всех экранах MVP; соответствуют accessibility по умолчанию; design tokens зафиксированы в едином источнике.

7. Нефункциональные требования

- **Производительность:** разбор Low/Medium кейса — секунды на экране; отклик UI — <1–2 сек
- **Безопасность:** ролевой доступ; аудит-лог tamper-evident (хеш/подписи — AMLR ст.77); хранение не менее и не более установленного срока (5 лет)
- **Доступность:** WCAG 2.1 AA
- **Платформы:** desktop web как приоритет; последние версии Chrome/Edge/Firefox/Safari; адаптивность для планшета — не приоритет MVP
- **Регуляторное ограничение на запуск:** DORA-требования к нам как ICT-третьей стороне должны быть закрыты организационно до контрактов с financial-entity клиентами

8. Риски и открытые вопросы

Из конкурентного анализа (threats)

- Дизинтермедиация вендорами — Sumsub и ComplyAdvantage одновременно наши вендоры и потенциальные конкуренты «снизу»
- Скорость регуляторной зрелости Alloy/Unit21 — могут формализовать наши дифференциаторы раньше нас
- UX-эталон Persona в нашей аудитории — риск при расширении её AML-глубины
- DORA как барьер входа для нас самих
- Bill shock в модели seats + usage overage
- Открытый GTM-вопрос — self-serve vs sales-led не решён

Из симулированного интервью (противоречия)

- Узкий формальный 4-eyes vs более лёгкий повседневный паттерн «второе мнение» (используется 4–5 раз в неделю)
- Ответственность за ошибочные Low-риск авто-одобрения задним числом — открытый вопрос
- Баланс между «разумным дефолтом SLA» и требованием обоснования, а не голой цифры

Вопросы, требующие реального customer development

- Реальное распределение риск-тиров у настоящих клиентов
- Готовы ли реальные CPO к self-serve входу или ожидают sales-led процесс
- Реальный SLA, который согласится соблюдать Senior Compliance Officer
- Юридическая позиция по ответственности за Low-риск авто-одобрения

9. Roadmap

Версия	Фичи	Приоритет
v1.0 (MVP)	14 Must have фич (см. раздел 5)	Must
v1.1	Внутренний поведенческий скоринг; confirm-диалог; полный список правил; три статуса решения; лёгкий паттерн «второе мнение»; маршрутизация на роль; SLA-таймер с обоснованием; эскалация при истечении SLA; пассивный индикатор статуса; авто-сворачивание Low; дашборд CPO; override rate + onboarding conversion; виджет прогноза счёта; полноценный OKR-дашборд; no-code конструктор правил; непрерывный мониторинг	Should
v2.0	Перевод метрик для CPO; read-only импорт исторических кейсов; публикация override rate как дифференциатора	Could
Не в дорожной карте	Self-serve вход/публичная цена; demo-дашборд до sales; free tier; кастомизация риск-матрицы под юрисдикцию	Won't (now)